

Marco Integrativo GQM + PRAGMATIC

Aplicado a Indicadores RGPD de Ciberseguridad y Riesgo

1. Propósito del marco

Este documento integra la metodología Goal–Question–Metric (GQM) con los nueve criterios PRAGMATIC (Predictivo, Relevante, Accionable, Genuino, Significativo, Preciso, Oportuno, Independiente, Rentable) aplicada a los indicadores de seguridad del tratamiento y cumplimiento RGPD descritos en el informe previo. [web:14][web:6][web:11][web:22][web:26]

El objetivo es garantizar trazabilidad clara entre:

- objetivos nacionales y organizativos de protección de datos y ciberseguridad,
- preguntas de evaluación que concretan dichos objetivos,
- métricas técnicas y de gestión que permiten responder a las preguntas.

2. Ejes de indicadores RGPD considerados

Los indicadores se agrupan en los ejes identificados a partir de guías y casos EDPB, memorias de autoridades (AEPD) y marcos ENISA/NIS2: [web:14][web:6][web:11][web:22][web:26]

1. Resultados de incidentes, brechas y sanciones.
2. Capacidad y madurez de controles (técnicos y organizativos).
3. Métricas operativas de ciberseguridad alineadas con RGPD.
4. Indicadores nacionales/regulatorios (reclamaciones, cooperación, sectores).
5. Síntesis en cuadros de mando (IGM) y datos económicos (ROI).

Sobre ellos se construyen los objetivos GQM.

3. GQM: de objetivos a métricas

Cada bloque define:

- Goal (G): objetivo de alto nivel (nacional/organizativo).
- Question (Q): preguntas que permiten evaluar el grado de logro del objetivo.
- Metric (M): métricas cuantitativas o cualitativas que responden a las preguntas. [web:9][web:28]

Abajo se esquematizan los objetivos principales (G1–G5):

- G1 – Reducir la frecuencia y el impacto de brechas de datos personales, especialmente las que afectan gravemente a derechos fundamentales.
- G2 – Asegurar que las medidas técnicas y organizativas son apropiadas al riesgo y se mantienen eficaces en el tiempo.
- G3 – Mejorar la capacidad de detección, respuesta y notificación de incidentes conforme a RGPD y NIS2.
- G4 – Garantizar una gestión adecuada de la cadena de suministro digital y de terceros que tratan datos personales.
- G5 – Desarrollar una cultura organizativa basada en datos (IGM, ROI) que permita decisiones informadas sobre riesgo, cumplimiento e inversión.

3.1. Eje 1 – Resultados: brechas, incidentes, sanciones (G1)

- G1: Reducir frecuencia e impacto de brechas de datos personales.
- Q1.1: ¿Cuántas brechas se producen y notifican en un periodo dado?
- Q1.2: ¿Cuál es el impacto medio por brecha (afectados, coste, gravedad)?
- Q1.3: ¿Qué proporción de brechas se mitiga eficazmente por medidas técnicas (cifrado, segmentación, pseudonimización)?
- Q1.4: ¿Cómo evolucionan las sanciones y reclamaciones ligadas a seguridad?

Métricas asociadas (ejemplos):

- M1.1: Número de brechas notificadas a la autoridad por año. [web:1][web:6][web:11]
- M1.2: Número total estimado de incidentes con impacto en datos personales (notificados + no notificables).
- M1.3: Porcentaje de brechas donde medidas técnicas limitaron el impacto. [web:14][web:21]
- M1.4: Importe total de sanciones RGPD/año por causas de seguridad. [web:3][web:6][web:11]
- M1.5: Número de reclamaciones relacionadas con seguridad del tratamiento. [web:6][web:11]

3.2. Eje 2 – Capacidad de controles y madurez (G2)

- G2: Disponer de un sistema de medidas técnicas y organizativas alineado con riesgo, estándares y guías (ENISA, AEPD, ISO). [web:25][web:21][web:23][web:27]
- Q2.1: ¿Qué cobertura real tienen cifrado, MFA, segmentación, monitorización?
- Q2.2: ¿Con qué rapidez se gestionan vulnerabilidades críticas?
- Q2.3: ¿Qué porcentaje de tratamientos incluye análisis de riesgos y EIPD?
- Q2.4: ¿Existe un SGSI/SGPI integrado y evaluaciones periódicas de madurez?

Métricas asociadas:

- M2.1: % de datos personales en reposo cifrados. [web:21][web:25]
- M2.2: % de datos en tránsito con cifrado robusto. [web:25]
- M2.3: % de sistemas relevantes con MFA activo. [web:22][web:26]
- M2.4: Tiempo medio de parcheo de vulnerabilidades críticas. [web:25]
- M2.5: % de tratamientos con análisis de riesgos/EIPD actualizados. [web:9][web:28]
- M2.6: Nivel de madurez ISO 27001/27701 o NIS2 (auto-evaluación). [web:23][web:27][web:22]

3.3. Eje 3 – Operación de ciberseguridad (G3)

- G3: Fortalecer la capacidad de detección, respuesta y notificación de incidentes conforme a RGPD y marcos de ciberseguridad. [web:25][web:22][web:26]
- Q3.1: ¿Cuál es el tiempo medio de detección de incidentes relevantes?
- Q3.2: ¿Cuál es el tiempo medio de contención y recuperación?
- Q3.3: ¿Se cumplen sistemáticamente los plazos de notificación (72 horas)?
- Q3.4: ¿Se ejecutan simulacros y se integran lecciones aprendidas?

Métricas asociadas:

- M3.1: MTTR-detección (Mean Time To Detect) de incidentes.
- M3.2: MTTR-respuesta/contención de incidentes.
- M3.3: % de brechas notificadas dentro de las 72 horas. [web:14][web:28]
- M3.4: N° de simulacros de incidentes al año. [web:25]
- M3.5: N° medio de acciones de mejora implementadas tras incidentes. [web:25]

3.4. Eje 4 – Terceros y cadena de suministro (G4)

- G4: Gestionar adecuadamente riesgos de terceros y proveedores que tratan datos personales. [web:28][web:23][web:27]
- Q4.1: ¿Qué cobertura tiene la evaluación de seguridad/privacidad de proveedores?
- Q4.2: ¿Qué porcentaje de proveedores críticos cuenta con certificaciones sólidas?
- Q4.3: ¿Existe monitorización continua de la postura de seguridad de terceros?

Métricas asociadas:

- M4.1: % de proveedores con evaluación de seguridad/privacidad vigente.
- M4.2: % de proveedores críticos con ISO 27001/27701, SOC 2 u otras certificaciones. [web:23][web:27]
- M4.3: N° de incidentes de seguridad originados en terceros por año. [web:25][web:28]
- M4.4: % de proveedores cubiertos por herramientas de security rating / monitoreo. [web:22][web:26]

3.5. Eje 5 – Cultura, métricas, IGM y ROI (G5)

- G5: Consolidar una cultura basada en datos que permita decisiones de riesgo e inversión informadas. [web:23][web:27][web:12]
- Q5.1: ¿Existe un cuadro de mando de ciberseguridad y RGPD operativo?
- Q5.2: ¿Se calcula un Índice Global de Madurez y se sigue su evolución?
- Q5.3: ¿Se estiman costes de incidentes e inversiones, y se calcula ROI?
- Q5.4: ¿Se dispone de métricas de formación y comportamiento del personal? [web:25]

Métricas asociadas:

- M5.1: Existencia y actualización del cuadro de mando (sí/no y frecuencia).
- M5.2: Valor IGM global y por bloque.
- M5.3: N° de reportes anuales al consejo con métricas de seguridad/RGPD. [web:23][web:27]
- M5.4: % de empleados con formación actualizada. [web:25][web:28]
- M5.5: ROI estimado de iniciativas clave de cumplimiento. [web:12][web:28]

4. PRAGMATIC: criterios para seleccionar métricas

Cada métrica se evalúa con los nueve criterios PRAGMATIC en escala 0–3

(0 = no cumple, 1 = bajo, 2 = medio, 3 = alto):

- P – Predictivo: ¿Anticipa resultados futuros (no solo describe el pasado)?
- R – Relevante: ¿Se alinea directamente con los objetivos GQM (G1–G5)?
- A – Accionable: ¿Conduce a decisiones claras (qué hacer diferente)?
- G – Genuino: ¿Refleja la realidad, sin incentivos perversos ni maquillaje fácil?
- M – Significativo (Meaningful): ¿Es comprensible y significativa para los stakeholders clave?
- P2 – Preciso: ¿Tiene exactitud y consistencia suficientes?
- T – Oportuno (Timely): ¿Se puede obtener con la frecuencia necesaria?
- I – Independiente: ¿No duplica otras métricas de forma redundante?
- C – Rentable (Cost-effective): ¿Su coste de obtención se justifica por el valor?

La Matriz PRAGMATIC completa con puntuaciones sugeridas por métrica se documenta en el archivo correspondiente.

5. Uso integrado GQM + PRAGMATIC

6. Definir o adaptar los objetivos G1–G5 al contexto nacional/organizativo.
7. Seleccionar las preguntas más relevantes (Q) por objetivo para el periodo.
8. Elegir un subconjunto manejable de métricas (M1.x–M5.x) evitando redundancias.
9. Evaluar cada métrica con PRAGMATIC y descartar las de baja calidad.
10. Vincular las métricas seleccionadas al cálculo de IGM y al análisis de ROI.
11. Revisar anualmente objetivos, preguntas y métricas conforme evolucionen amenazas, regulación y tecnología. [web:14][web:25][web:22][web:26]

El resultado es un sistema de medición en el que cada gráfico del cuadro de mando puede rastrearse hasta un objetivo regulatorio o estratégico, pasando por una pregunta GQM y superando el filtro de calidad PRAGMATIC.